

Security Assessment Report of GitHub

Name: AMEEBEN VAISHNAV

Date: 23rd June 2026

Executive Summary

This report presents a security assessment of GitHub. The assessment evaluates major website functionalities, security controls, potential risks, and recommendations. GitHub implements strong security features such as HTTPS, Two-Factor Authentication, Email Verification, and Secure Password Recovery.

Scope of Assessment

The assessment covers:

- Login Page
- Registration Page
- Forgot Password Functionality
- Contact/Support Form
- Search Functionality
- User Profile Section
- Security Features including HTTPS, CAPTCHA, 2FA, Email Verification, Session Management, and Password Reset Mechanism

Methodology

1. Reviewed GitHub website features.
2. Identified implemented security controls.
3. Analyzed potential security risks.
4. Classified risks based on severity.
5. Provided security recommendations.

PART 1: WEBSITE SECURITY REVIEW

Choose any website or your own application.

Analyze the following:

1. Login Page
2. Registration Page
3. Forgot Password Functionality
4. Contact Form
5. Search Functionality
6. User Profile Section

Create a table:

Feature | Purpose | Security Risks | Recommendations

Selected Website

Website Name: GitHub

Introduction

GitHub is a widely used web-based platform for software development and version control. It allows developers to host, manage, and collaborate on projects using Git. Since GitHub handles sensitive information such as user credentials, source code repositories, and account settings, it implements various security mechanisms to protect user data and maintain platform integrity. This assessment reviews the security aspects of key functionalities available on the GitHub website.

1. Login Page

Purpose

The Login Page allows registered users to securely access their GitHub accounts by providing their username or email address and password. It serves as the primary authentication gateway for users.

Security Features Observed

- Secure HTTPS connection.
- Username/email and password authentication.
- Support for Two-Factor Authentication (2FA).
- Detection of suspicious login attempts.
- Session management after successful login.

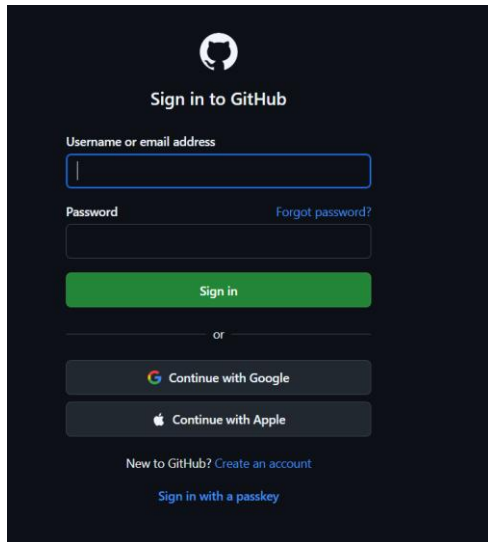
Security Risks

- Brute-force attacks where attackers repeatedly attempt password guesses.
- Credential stuffing using usernames and passwords leaked from other websites.
- Phishing attacks that trick users into revealing login credentials.
- Unauthorized access through weak or reused passwords.

Recommendations

- Enforce strong password requirements.
- Encourage all users to enable Two-Factor Authentication.
- Implement account lockout or rate-limiting mechanisms.
- Notify users about suspicious login attempts.

Screenshot:



2. Registration Page

Purpose

The Registration Page allows new users to create GitHub accounts by providing personal information such as username, email address, and password.

Security Features Observed

- Email verification requirement.
- Password strength validation.
- HTTPS encryption during account creation.
- Bot protection mechanisms to prevent automated registrations.

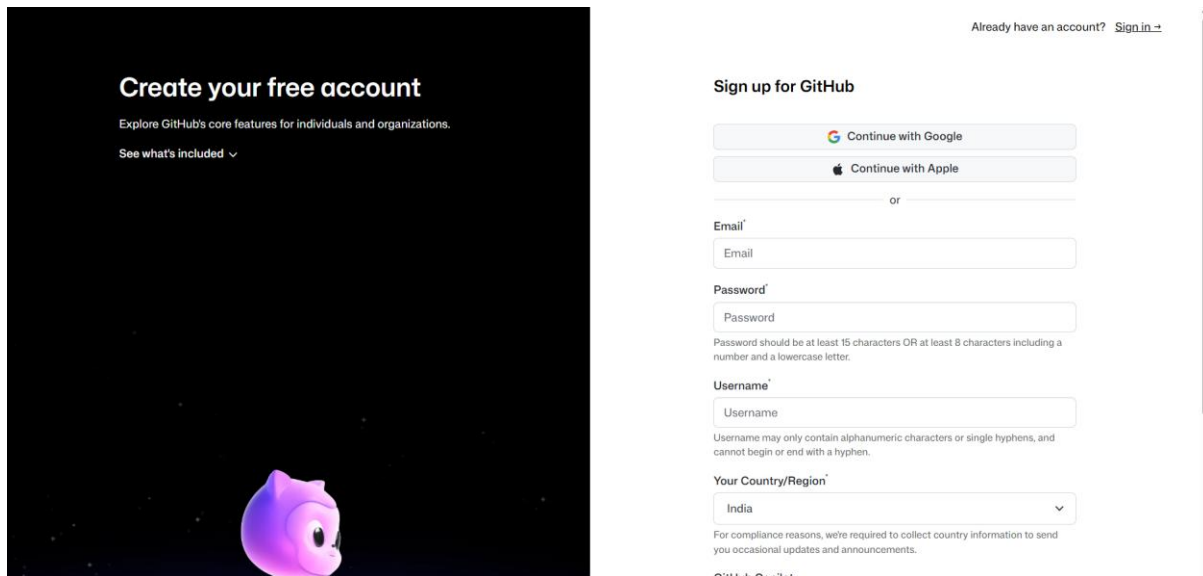
Security Risks

- Creation of fake or malicious accounts.
- Automated bot registrations.
- Use of weak passwords.
- Submission of invalid or temporary email addresses.

Recommendations

- Enforce stronger password complexity requirements.
- Continue using email verification before account activation.
- Apply CAPTCHA when suspicious registration activity is detected.
- Monitor and limit repeated account creation attempts.

Screenshot:



Already have an account? [Sign in](#)

Create your free account

Explore GitHub's core features for individuals and organizations.

[See what's included](#)

Sign up for GitHub

[Continue with Google](#)

[Continue with Apple](#)

or

Email*

Password*

Username*

Your Country/Region*

India

For compliance reasons, we're required to collect country information to send you occasional updates and announcements.

3. Forgot Password Functionality

Purpose

The Forgot Password feature helps users regain access to their accounts when they forget their passwords. Users can request a password reset link through their registered email address.

Security Features Observed

- Password reset links are sent only to verified email addresses.
- Password reset links expire after a certain period.
- Secure HTTPS communication during the reset process.
- User notifications for password reset requests.

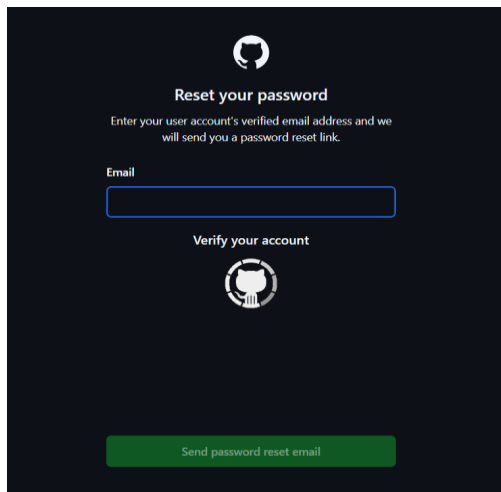
Security Risks

- Unauthorized password resets if an attacker gains access to the user's email account.
- Phishing attacks that mimic legitimate password reset emails.
- Abuse of password reset functionality to harass users.

Recommendations

- Maintain short expiration periods for reset links.
- Require additional verification for sensitive accounts.
- Notify users immediately when password reset requests are initiated.
- Monitor excessive password reset requests from the same source.

Screenshot:



4. Contact / Support Form

Purpose

GitHub provides support channels that allow users to submit technical issues, account-related concerns, and security reports.

Security Features Observed

- Secure HTTPS transmission.
- Input validation for submitted information.
- Protection against unauthorized access to support requests.
- Secure handling of user-submitted data.

Security Risks

- Spam submissions.
- Phishing attempts through support messages.
- Injection attacks through improperly validated input fields.
- Exposure of confidential information if support tickets are not properly secured.

Recommendations

- Implement CAPTCHA for public submission forms.
- Sanitize and validate all user inputs.
- Apply rate limiting to prevent abuse.
- Educate users not to submit sensitive credentials through support forms.

5. Search Functionality

Purpose

The Search Functionality allows users to search repositories, users, organizations, documentation, and code hosted on GitHub.

Security Features Observed

- Input validation and filtering.
- HTTPS encryption.
- Access control mechanisms that restrict private repository searches to authorized users.
- Monitoring of unusual search behavior.

Security Risks

- Information gathering by attackers during reconnaissance activities.
- Automated scraping of public information.
- Excessive search requests causing resource consumption.
- Potential exposure of sensitive information accidentally published in public repositories.

Recommendations

- Continue enforcing strict access controls.
- Monitor large-scale automated search activities.
- Educate users about protecting sensitive information in repositories.
- Implement rate limiting to prevent abuse.

6. User Profile Section

Purpose

The User Profile Section allows users to manage personal information, repositories, account settings, security preferences, and public profile details.

Security Features Observed

- Privacy settings for profile information.
- Two-Factor Authentication support.
- Session and device management.
- Security logs and account activity monitoring.
- HTTPS protection for profile management activities.

Security Risks

- Exposure of personal information through public profiles.
- Account takeover through compromised credentials.
- Unauthorized modifications to account settings.
- Leakage of sensitive project information.

Recommendations

- Enable Two-Factor Authentication for all users.
- Review profile privacy settings regularly.
- Use strong and unique passwords.
- Monitor account activity and login history.
- Restrict unnecessary public disclosure of personal information.

Summary Table

Feature	Purpose	Security Risks	Recommendations
Login Page	User authentication and account access	Brute-force attacks, phishing, credential stuffing	Strong passwords, 2FA, rate limiting
Registration Page	New account creation	Fake accounts, bots, weak passwords	Email verification, CAPTCHA, password policies
Forgot Password	Password recovery	Unauthorized resets, phishing	Expiring reset links, user notifications
Contact Form	User support communication	Spam, injection attacks, information disclosure	CAPTCHA, input validation, rate limiting
Search Functionality	Search repositories and users	Information gathering, scraping	Access controls, monitoring, rate limiting
User Profile Section	Manage account and personal information	Privacy leaks, account takeover	2FA, privacy controls, activity monitoring

PART 2: SECURITY FEATURE ANALYSIS

Identify and document the following security features:

- **HTTPS**
- **CAPTCHA**
- **Two-Factor Authentication (2FA)**
- **Email Verification**
- **Password Complexity Rules**
- **Session Timeout**
- **Password Reset Mechanism**

Take screenshots wherever applicable.

1. HTTPS (Hypertext Transfer Protocol Secure)

Description

HTTPS is a secure version of HTTP that encrypts communication between the user's browser and GitHub's servers using SSL/TLS protocols.

Observation

GitHub uses HTTPS across all pages, including:

- Login Page
- Registration Page
- Password Reset Pages
- User Profile Pages
- Repository Pages

A padlock icon appears in the browser address bar, indicating a secure connection.

Security Benefits

- Encrypts data during transmission.
- Prevents eavesdropping by attackers.
- Protects usernames and passwords from interception.
- Ensures data integrity.
- Verifies the authenticity of the website.

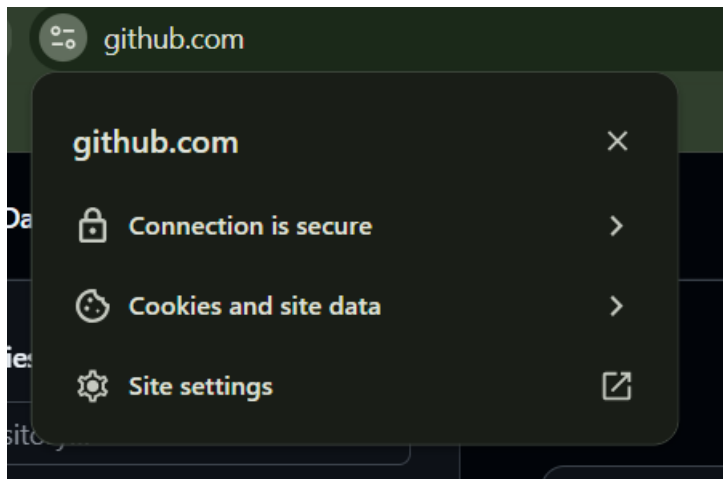
Risks if Not Implemented

- Man-in-the-Middle (MITM) attacks.
- Data theft during transmission.
- Session hijacking.
- Credential interception.

Assessment

Status: Implemented

Screenshot :



2. CAPTCHA Protection

Description

CAPTCHA (Completely Automated Public Turing Test to Tell Computers and Humans Apart) helps distinguish human users from automated bots.

Observation

GitHub may display CAPTCHA challenges during:

- Account registration.
- Suspicious login attempts.
- Unusual account activities.
- Repeated requests from the same IP address.

CAPTCHA is generally triggered when GitHub detects potentially automated behavior.

Security Benefits

- Prevents automated account creation.
- Reduces spam and abuse.
- Blocks brute-force login attempts.
- Protects server resources from bots.

Risks if Not Implemented

- Large-scale fake account creation.
- Automated attacks.
- Spam submissions.
- Credential stuffing attacks.

Assessment

Status: Implemented When Required

3. Two-Factor Authentication (2FA)

Description

Two-Factor Authentication adds an additional security layer beyond passwords. Users must provide a second verification factor after entering their password.

Observation

GitHub supports:

- Authentication Apps
- Security Keys
- Passkeys
- Recovery Codes

Users can configure 2FA through the Security Settings page.

Security Benefits

- Protects accounts even if passwords are stolen.
- Reduces account takeover risks.
- Prevents unauthorized access.
- Improves overall account security.

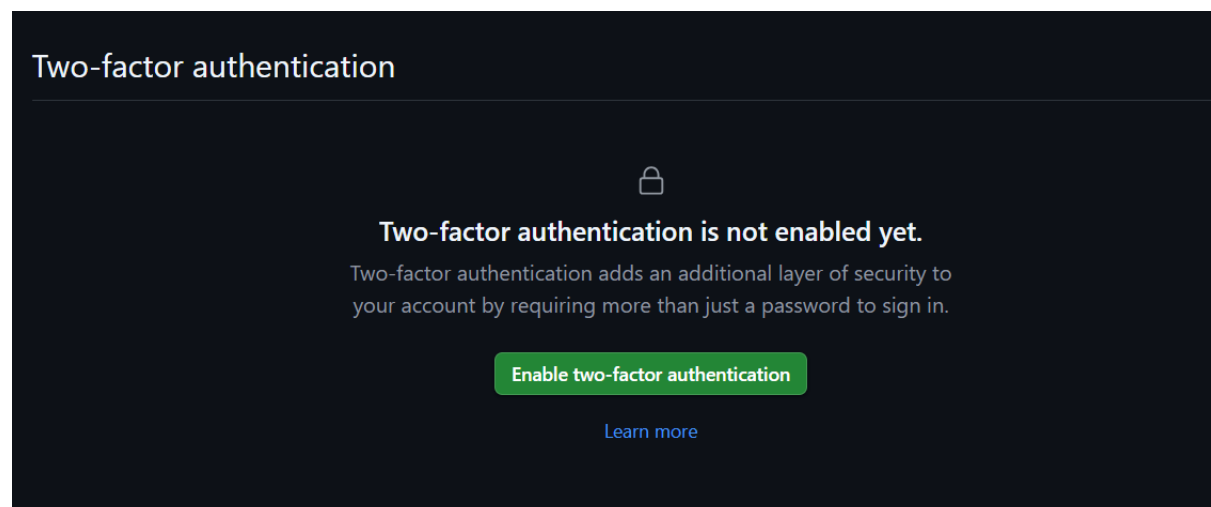
Risks if Not Implemented

- Single-password compromise leads to account access.
- Increased risk of credential theft.
- Higher vulnerability to phishing attacks.

Assessment

Status: Available and Recommended

Screenshot:



4. Email Verification

Description

Email verification confirms that users own the email address provided during registration.

Observation

GitHub requires users to verify their email addresses before accessing certain account features.

Verification occurs through:

1. Registration.
2. Email containing a verification link.
3. User clicks the verification link.
4. Account email becomes verified.

Security Benefits

- Prevents fake account creation.
- Confirms user identity.
- Improves account recovery reliability.
- Reduces spam accounts.

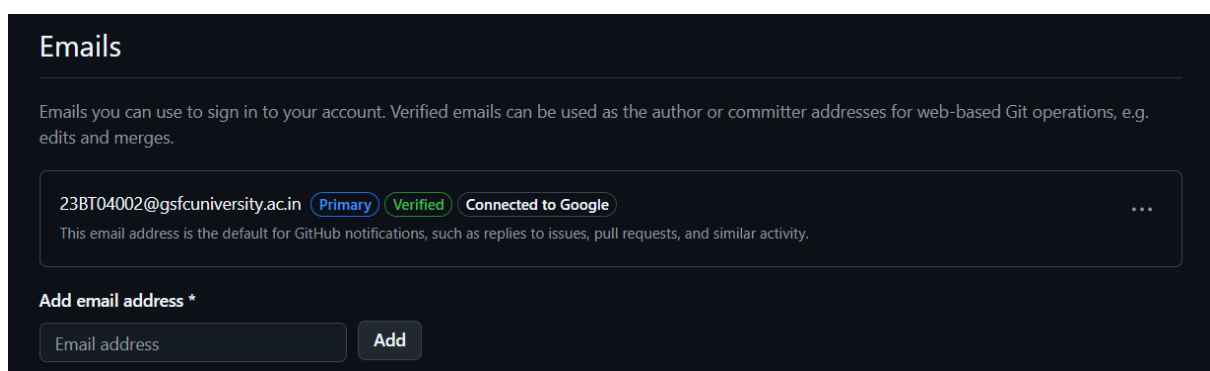
Risks if Not Implemented

- Use of fake email addresses.
- Difficulty recovering accounts.
- Increased malicious account creation.

Assessment

Status: Implemented

Screenshot:



5. Password Complexity Rules

Description

Password complexity requirements ensure users create strong passwords that are difficult to guess or crack.

Observation

GitHub enforces:

- Minimum password length requirements.
- Detection of weak passwords.
- Prevention of commonly used passwords.
- Secure password storage mechanisms.

Users receive warnings when weak passwords are entered.

Security Benefits

- Reduces brute-force attack success.
- Prevents dictionary attacks.
- Improves overall account security.
- Protects against credential guessing.

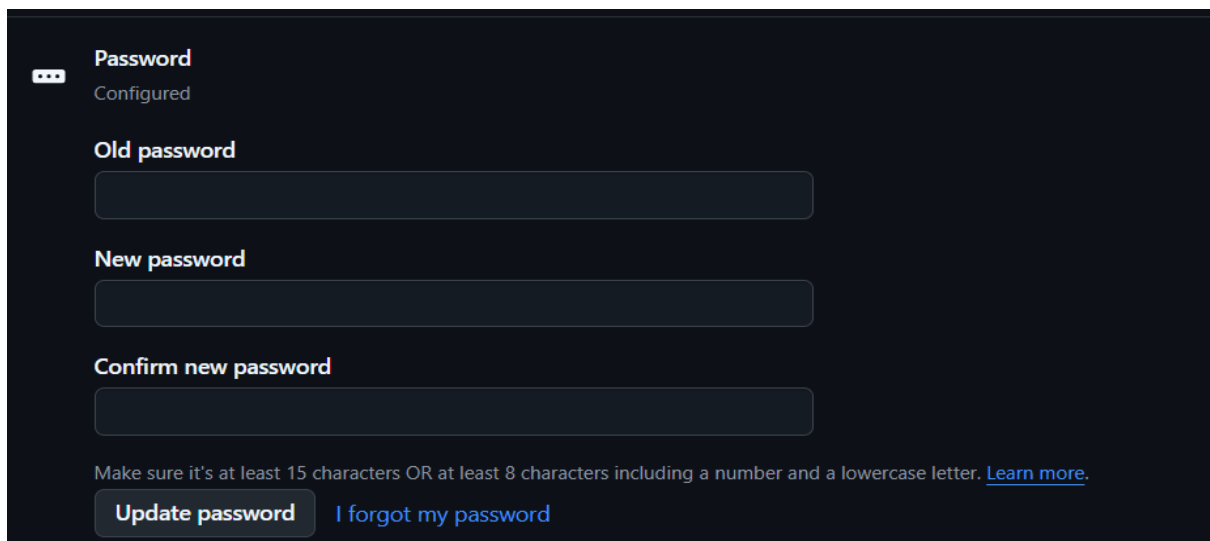
Risks if Not Implemented

- Weak passwords become easy targets.
- Increased unauthorized access.
- Higher account compromise risk.

Assessment

Status: Implemented

Screenshot:



The screenshot shows a dark-themed user interface for password management. At the top, there is a header section with a three-dot menu icon, the title "Password", and the status "Configured". Below this, there are three input fields: "Old password", "New password", and "Confirm new password". At the bottom, there is a text requirement: "Make sure it's at least 15 characters OR at least 8 characters including a number and a lowercase letter. [Learn more.](#)". Below the text are two buttons: "Update password" and "I forgot my password".

6. Session Timeout and Session Management

Description

Session management controls how long authenticated users remain logged in and allows monitoring of active sessions.

Observation

GitHub:

- Uses secure session cookies.
- Maintains authenticated sessions.
- Allows users to review active sessions.
- Terminates sessions after logout.
- Supports device and session management.

Security Benefits

- Reduces risks from abandoned sessions.
- Prevents unauthorized use of active sessions.
- Improves account monitoring.
- Allows users to detect suspicious activity.

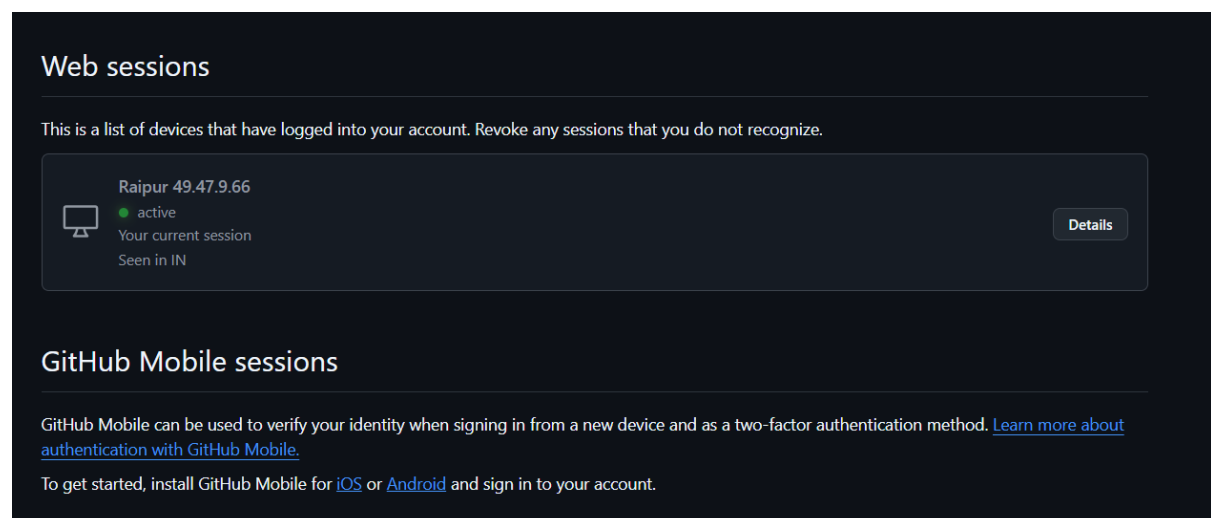
Risks if Not Implemented

- Session hijacking.
- Unauthorized account access.
- Misuse of unattended devices.

Assessment

Status: Implemented

Screenshot :



7. Password Reset Mechanism

Description

The Password Reset Mechanism enables users to securely regain access when they forget their passwords.

Observation

GitHub's password reset process includes:

1. User selects "Forgot Password".
2. Registered email is entered.
3. Password reset link is sent via email.
4. User accesses the link.
5. New password is created.

Password reset links are temporary and expire after a specific period.

Security Benefits

- Secure account recovery.
- Verification through registered email.
- Temporary reset links reduce misuse.
- User notification enhances awareness.

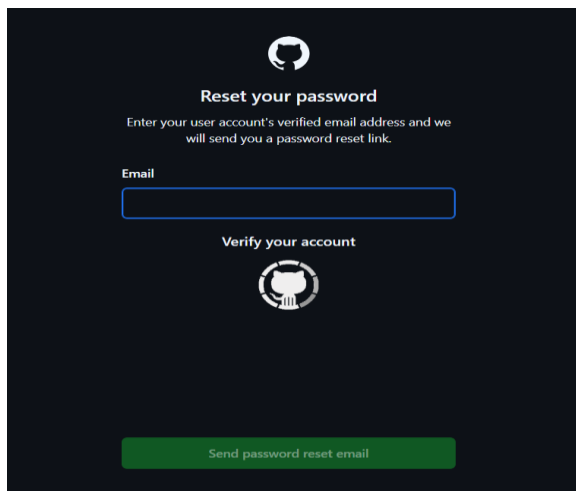
Risks if Not Implemented

- Users may lose account access permanently.
- Weak recovery methods could be exploited.
- Increased support burden.

Assessment

Status: Implemented

Screenshot :



PART 3: SECURITY OBSERVATIONS

For the selected website, answer:

1. What Sensitive Information Does the Application Handle?

GitHub handles several types of sensitive information that require protection.

A. User Credentials

Examples:

- Username
- Email Address
- Password
- 2FA Codes
- Recovery Codes

Importance: Compromise of these credentials can lead to unauthorized access to user accounts and repositories.

B. Personal Information

Examples:

- Full Name
- Profile Photo
- Biography
- Location
- Website Links

Importance: Exposure may result in privacy violations, phishing attacks, or social engineering.

C. Source Code Repositories

Examples:

- Public and Private Repositories
- Source Code
- Configuration Files
- Project Documentation

Importance: Unauthorized access can expose intellectual property and sensitive business information.

D. Authentication and Security Data

Examples:

- Active Sessions
- Login History
- Authentication Tokens
- SSH Keys
- API Keys

Importance: Exposure may allow attackers to bypass security controls and gain unauthorized access.

E. Project Collaboration Data

Examples:

- Pull Requests
- Issues

Importance: Unauthorized access may reveal confidential project details.

2. Which Security Controls Are Implemented?

- **HTTPS Encryption:**Secures communication between users and GitHub servers through encrypted connections.
- **Two-Factor Authentication (2FA):**Supports Authenticator Apps, Security Keys, Passkeys, and Recovery Codes to provide an additional layer of security.
- **Email Verification:**Verifies ownership of email addresses and helps prevent fake account creation.
- **Password Security Controls:**Enforces password requirements and detects weak passwords to reduce unauthorized access.
- **Session Management:**Includes secure session cookies, login history monitoring, device recognition, and session termination after logout.
- **Account Recovery Mechanism:**Allows secure password recovery through registered email accounts.
- **Security Monitoring and Alerts:**Notifies users about important security events such as new logins, password changes, and security setting updates.

3. What Are the Possible Security Risks?

Risk	Impact	Likelihood	Severity
Phishing Attacks	Account compromise and data theft	Medium	High
Credential Stuffing	Unauthorized account access	Medium	High
Weak Password Usage	Increased account compromise risk	Medium	Medium
Exposure of Sensitive Data	Data breaches and unauthorized access	Medium	High
Session Hijacking	Unauthorized access to active sessions	Low	High
Social Engineering	Credential theft and account compromise	Medium	Medium
Third-Party Integration Risks	Data leakage and unauthorized access	Medium	Medium

4. What improvements would you recommend?

- **Mandatory Two-Factor Authentication:**-Require 2FA for all users to reduce account takeover risks.
- **Advanced Phishing Protection:**-Implement stronger phishing detection and warning mechanisms.
- **Security Awareness Programs:**-Educate users about phishing, social engineering, and safe security practices.
- **Stronger Password Policies:**-Encourage longer and more complex passwords.
- **Automated Secret Detection:**-Improve scanning for exposed API keys, tokens, and credentials.
- **Enhanced Login Monitoring:**-Detect and respond to unusual login activities more effectively.
- **Improved Third-Party Application Review:**-Strengthen security assessments of integrated applications.

Overall Security Assessment

Category	Assessment
Data Protection	Strong
Authentication Security	Strong
Encryption	Strong
Access Control	Strong
Session Management	Strong
User Awareness	Moderate
Third-Party Security	Moderate
Overall Security Posture	Strong

Conclusion

GitHub implements strong security controls including HTTPS, 2FA, email verification, secure session management, and password recovery mechanisms. While risks such as phishing, credential theft, and accidental exposure of sensitive information remain, the platform maintains a strong overall security posture.

PART 4: RISK CLASSIFICATION

Categorize your observations into:

- **Critical Risk**
- **High Risk**
- **Medium Risk**
- **Low Risk**
- **Informational**

Explain why each issue belongs to that category.

Risk Classification Criteria

Risk Level	Description
Critical	Vulnerabilities that can result in complete system compromise, major data breaches, or severe business impact. Immediate action is required.
High	Vulnerabilities that can significantly affect confidentiality, integrity, or availability of systems and data. Prompt remediation is necessary.
Medium	Vulnerabilities that present moderate security concerns and may lead to exploitation under specific conditions.
Low	Vulnerabilities with limited impact and lower likelihood of exploitation.
Informational	Security observations that do not directly create vulnerabilities but provide useful security-related information.

1. Critical Risk

Observation: Exposure of Sensitive Credentials in Repositories

Description

Developers may accidentally upload sensitive information such as API keys, authentication tokens, passwords, database credentials, or private certificates to public repositories.

Potential Impact

- Unauthorized system access
- Data breaches
- Financial losses
- Compromise of connected services
- Exposure of confidential organizational information

Why It Is Classified as Critical

- Direct access to sensitive systems is possible.
- Exploitation may occur immediately after exposure.
- Large-scale compromise can result.
- Business operations may be severely affected.

Recommendation

- Use secret scanning tools.
- Remove exposed credentials immediately.
- Rotate compromised keys and passwords.
- Implement automated secret detection before code publication.

2. High Risk

Observation 1: Phishing Attacks

Description

Attackers may create fake GitHub login pages to trick users into entering their credentials.

Potential Impact

- Account takeover
- Unauthorized repository access
- Theft of source code
- Compromise of organizational projects

Why It Is Classified as High

- Frequently used attack technique.
- Can lead to complete account compromise.
- Significant impact on confidentiality and integrity.

Recommendation

- Enable Two-Factor Authentication.
- Educate users about phishing awareness.
- Verify website URLs before login.

Observation 2: Credential Stuffing Attacks

Description

Attackers use usernames and passwords obtained from previous data breaches to access GitHub accounts.

Potential Impact

- Unauthorized account access
- Data exposure

- Repository manipulation

Why It Is Classified as High

- Common attack method.
- High success rate when users reuse passwords.
- May compromise multiple accounts.

Recommendation

- Use unique passwords.
- Enable Two-Factor Authentication.
- Monitor suspicious login activities.

Observation 3: Session Hijacking

Description

Attackers attempt to steal session cookies or authentication tokens to gain access to active user sessions.

Potential Impact

- Unauthorized access without needing credentials.
- Account compromise.
- Data manipulation.

Why It Is Classified as High

- Bypasses normal authentication.
- Can provide full access to user accounts.

Recommendation

- Use secure session cookies.
- Terminate inactive sessions.
- Monitor unusual session activity.

3. Medium Risk

Observation 1: Weak Password Usage

Description

Some users may choose weak, predictable, or reused passwords.

Potential Impact

- Easier password cracking.
- Increased risk of unauthorized access.

Why It Is Classified as Medium

- Exploitation requires additional attack efforts.

- Password policies partially reduce risk.
- Impact depends on user behavior.

Recommendation

- Enforce stronger password policies.
- Encourage password managers.
- Promote long passphrases.

Observation 2: Social Engineering Attacks

Description

Attackers manipulate users into revealing sensitive information.

Potential Impact

- Credential theft.
- Unauthorized account access.
- Information disclosure.

Why It Is Classified as Medium

- Relies on human error.
- Success depends on user awareness.

Recommendation

- Conduct security awareness training.
- Educate users about social engineering tactics.

Observation 3: Third-Party Application Risks

Description

Users may authorize external applications that request access to GitHub accounts and repositories.

Potential Impact

- Unauthorized data access.
- Information leakage.
- Abuse of repository permissions.

Why It Is Classified as Medium

- Depends on application security.
- Limited by granted permissions.

Recommendation

- Review application permissions regularly.
- Remove unused integrations.

- Authorize only trusted applications.

4. Low Risk

Observation 1: Public Profile Information Exposure

Description

Users may voluntarily publish information on their public profiles.

Potential Impact

- Minor privacy concerns.
- Information gathering by attackers.

Why It Is Classified as Low

- Information is intentionally shared.
- Limited direct security impact.

Recommendation

- Review profile privacy settings.
- Avoid sharing unnecessary personal information.

Observation 2: Automated Repository Scraping

Description

Attackers may collect publicly available repository information through automated tools.

Potential Impact

- Information gathering.
- Reconnaissance activities.

Why It Is Classified as Low

- Public repositories are intended for public access.
- Limited impact when no sensitive information is exposed.

Recommendation

- Avoid storing sensitive information in public repositories.
- Review repository visibility settings.

5. Informational Findings

Observation 1: HTTPS Implementation

Description

GitHub uses HTTPS across all web pages.

Security Benefit

- Encrypts data transmission.
- Protects user credentials.
- Ensures communication confidentiality.

Why It Is Informational

- Represents a positive security control rather than a vulnerability.

Observation 2: Email Verification

Description

GitHub verifies user email addresses during account registration.

Security Benefit

- Prevents fake account creation.
- Supports account recovery.

Why It Is Informational

- Security feature successfully implemented.

Observation 3: Two-Factor Authentication Availability

Description

GitHub offers Two-Factor Authentication to users.

Security Benefit

- Adds an additional authentication layer.
- Protects against password compromise.

Why It Is Informational

- Strong security control already present.

Observation 4: Secure Password Reset Mechanism

Description

Password reset requests require access to the registered email account.

Security Benefit

- Secure account recovery.
- Reduces unauthorized password changes.

Why It Is Informational

- Represents a protective security feature.

COMPARISON OF GITHUB WITH MY OWN WEBSITE

Security Comparison Table

Security Aspect	GitHub	My Website
Authentication Security	Supports username/email login, password authentication, and Two-Factor Authentication (2FA).	Supports basic username/email and password authentication.
Password Policy	Enforces strong passwords, checks for weak passwords, and recommends secure credentials.	Requires a minimum password length but has limited password complexity checks.
User Verification	Email verification is mandatory during account registration.	Email verification is implemented for new user accounts.
Forgot Password Feature	Secure password reset links are sent to verified email addresses.	Password reset functionality is available through registered email accounts.
Session Management	Secure session cookies, device tracking, login history, and active session monitoring.	Session management through cookies; active session monitoring is limited.
HTTPS Security	Fully encrypted communication using HTTPS across all pages.	HTTPS enabled to protect user data during transmission.
CAPTCHA Protection	CAPTCHA is used during suspicious login or registration activities.	CAPTCHA implemented on registration and contact forms.
Two-Factor Authentication (2FA)	Available and highly recommended for all users.	Not currently implemented.
Account Activity Monitoring	Users can view login history and security events.	Basic login tracking is available.
Security Alerts	Sends notifications for suspicious logins and security changes.	Limited notification functionality.
Protection Against Automated Attacks	Advanced bot detection and rate-limiting mechanisms.	Basic CAPTCHA protection available.
Profile Privacy Controls	Extensive privacy and security settings for users.	Limited profile privacy settings.

Security Aspect	GitHub	My Website
Third-Party Integration Security	Permission-based access control for connected applications.	Third-party integrations are minimal or unavailable.

Analysis of Comparison

- Authentication Security:**
 GitHub offers stronger authentication through Two-Factor Authentication (2FA), security keys, and login monitoring. My website mainly uses username and password authentication.
- Password Policy:**
 GitHub enforces stronger password requirements and checks for weak passwords, while my website provides basic password validation.
- User Verification:**
 Both platforms use email verification, but GitHub has a more advanced verification and recovery process.
- Session Management:**
 GitHub provides login history, device management, and session tracking. My website offers basic session handling.
- Additional Security Features:**
 GitHub includes 2FA, security alerts, device recognition, secret scanning, and advanced access controls. My website provides HTTPS, email verification, CAPTCHA, and password recovery.